

LMJuly18-01 — LaunchMind: Overview & Architecture

Date: July 18, 2026 · Part 1 of 6

Table of Contents

- [Product Vision](#)
 - [Core Loop](#)
 - [Markets & Pricing](#)
 - [Tech Stack](#)
 - [Non-Negotiable Build Rules](#)
 - [Infrastructure](#)
 - [Security Architecture](#)
 - [Environment & Secrets](#)
 - [CI/CD Pipeline](#)
 - [Branch Strategy](#)
-

1. Product Vision

LaunchMind is an **AI marketing operating system for app founders**. It removes the guesswork from mobile app marketing by automating strategy, content creation, campaign management, and performance analysis — all from a single URL paste.

Problem it solves: App founders know how to build but not how to market. They waste time on manual content creation, don't know which channels work for their category, and have no system for learning from results. **Solution:** Paste your App Store or Play Store URL → LaunchMind scrapes your product, builds your ICP, generates a 30/60/90 day strategy, writes all content assets, runs campaigns across Meta/Google/WhatsApp/LinkedIn/Email, and delivers a weekly brief every Sunday with what worked and what to kill.

2. Core Loop

DISCOVER → CONFIRM → EXECUTE → LEARN

Step	Action	Output
1. Discover	Paste App Store / Play Store URL	Scraped product intel (ICP, competitors, screenshots, brand voice)
2. Confirm	Review + edit scraped ICP brief	Confirmed ICP, competitor set, target markets, brand voice profile
3. Execute	Generate 30/60/90 day strategy + content assets	Strategy doc, campaigns across USA + India channels, content assets (text/video/visual/audio)
4. Learn	Weekly Sunday brief → Tuesday retargeting loop	What worked, what to kill, next actions, retargeting triggers

3. Markets & Pricing

Markets

- **USA:** Stripe, USD, Meta/Google/LinkedIn/Email channels
- **India:** Razorpay, INR, WhatsApp Business/Google/Email channels (UPI, cards, net banking)

Pricing Tiers

Tier	Price (USD/month)		Price (INR/month)	Token Balance	Key Features
Free	\$0	₹0	50 tokens	1 product, basic strategy	
Solo	\$19	₹999	300 tokens	1 product, all channels, weekly briefs	
Builder	\$49	₹2,499	1,000 tokens	3 products, playbook insights, recommendations	
Studio	\$99	₹4,999	3,000 tokens	10 products, workspaces, API keys, all features	

Token Cost Reference

Action	Tokens	Model
Strategy generation	50	Sonnet
Weekly brief	20	Sonnet
Content asset batch	20	Sonnet
Review analysis	15	Haiku
ICP structuring	10	Haiku

Brand voice extract	10	Haiku
Brand voice apply	5	Haiku
Scoring / classify	5	Haiku

4. Tech Stack

Locked Stack (no alternatives)

Layer	Tool	Notes
Frontend	Next.js 14 App Router	No alternatives
UI library	Tailwind CSS + shadcn/ui	Do not build custom equivalents of shadcn components
Frontend host	Vercel	Auto-deploy on push to main
Backend	Node.js + Fastify	Typed routes, Zod validation
Backend host	Oracle Cloud VM	Docker + Nginx + CI/CD pipeline
Primary DB	Supabase Postgres	RLS on every table from migration 001
Vector store	pgvector (in Supabase)	No separate Pinecone
Cache + Queue	Upstash Redis + BullMQ	Weekly cron + job retries
AI strategy/copy	claude-sonnet-4-6	Complex generation
AI scoring/classify	claude-haiku-4-5-20251001	Fast, cheap classification
Scraping static	Cheerio	App Store metadata
Scraping dynamic	Playwright	Play Store + reviews — sandboxed worker
Token encryption	AES-256 + AWS KMS	OAuth tokens only. Key never in DB
Perimeter	Cloudflare WAF	DNS, DDoS, rate limit, TLS 1.3 only
Email	Resend	Transactional + weekly briefs
Payments USA	Stripe	Subscriptions + token top-up packs
Payments India	Razorpay	UPI + cards + net banking
Image generation	Flux.1 Schnell via Replicate	Style system: photorealistic / graphic / mockup
Video rendering	Creatomate API	Graceful mock if key missing
Voice synthesis	ElevenLabs API	Graceful mock if key missing
Error tracking	Sentry	Wired into Fastify error handler first

Product analytics	PostHog	Fires only after cookie consent
Audit logs	Axiom	Immutable append-only
Auth	Supabase Auth	15-min JWT (ES256) + rotating refresh tokens
MFA	TOTP via Supabase Auth	Enforced for ALL accounts. Cannot be disabled
E2E tests	Playwright	Sanity + regression per phase
Unit/integration	Vitest	Backend routes + services
SAST	Semgrep + ESLint security plugin	Blocks merge on HIGH+
DAST	OWASP ZAP	Runs on staging before each phase promotion
Dependency scan	Snyk + npm audit	Blocks deploy on HIGH+ CVE

5. Non-Negotiable Build Rules

These apply to **every task, every file, every commit**. No exceptions.

5.1 Backend First — Always

1. DB migration (additive only)
 - Fastify route + handler
 - Unit test for the handler
 - Integration test against Supabase local
 - Only then: Next.js page / component

5.2 Additive Migrations Only

- NEVER drop, rename, or retype a column
- NEVER delete a table
- All migrations: `YYYYMMDD_HHMMSS_description.sql`
- All migrations must be idempotent (safe to run twice)

5.3 Memory of Existing Implementation

Before writing any new code:

- Read every file you will touch — completely

- List every function/route/type the new code will interact with
- Confirm no existing function signatures will change
- Run existing tests first — all must pass before adding new code

5.4 Token-Ready from Day 1

Every Claude API call routes through:

```
await consumeTokens(founderId, action, estimatedCost);
```

Phases 1–4: no-op (logs only). Phase 5: enforces balance. Function signature never changes.

5.5 Approve-Before-Post — Hard Server-Side Constraint

No campaign posts to any platform unless `campaigns.approved_at` is non-null. Checked in the Fastify route handler. Frontend cannot bypass this.

5.6 Spend Guardrails — Hard Server-Side Limit

Before any paid campaign creation:

- Fetch `campaigns.spend_cap` for founder + platform
- Fetch current week spend from platform API
- If (current + proposed) > cap → reject 422

5.7 AI Platform Mandatory Entry Point

All AI calls MUST go through `aiPlatform.ts`. No direct `@anthropic-ai/sdk` calls outside `aiClient.ts`.

- `callSonnet(system, user, maxTokens, auditCtx, schema?)` — `auditCtx` is REQUIRED
- `callHaiku(prompt, maxTokens, auditCtx)` — `auditCtx` is REQUIRED
- AuditContext shape: `{ founderId?: stringnull; productId?: stringnull; promptId: string; action: string }`

6. Infrastructure

6.1 Oracle Cloud VM (Backend)

```
VM → Docker → Nginx (reverse proxy, SSL) → Fastify API (port 3001)
                                   → Playwright scraper (separate container)
```

Key files:

- `docker-compose.prod.yml` — production orchestration
- `docker-compose.yml` — local dev
- `nginx.conf` — reverse proxy + SSL termination
- `backend/Dockerfile` — main API image
- `backend/Dockerfile.scrapers` — Playwright scraper image (sandboxed)
- `backend/oracle-deploy.sh` — deployment script

The backend loads `.env.local` from the project root at startup (local dev only). In production, env vars are set directly on the Oracle VM.

6.2 Vercel (Frontend)

- Auto-deploy on push to `main`
- Edge middleware (`middleware.ts`) handles auth redirect (authenticated users → `/dashboard/brief`)
- Env vars set in Vercel dashboard
- `NEXT_PUBLIC_API_URL` points to Oracle VM backend

6.3 Supabase (`gseqtbwdenjkwysregpp`)

- Postgres + pgvector extension
- RLS enabled on every founder-data table
- Auth: ES256 JWT (rotated from HS256 on 2026-05-16), 15-min access tokens, rotating refresh tokens
- Storage bucket: `content-assets` — marketing images, screenshots, brand assets
- Service role key used in backend (`getSupabaseAdmin()`). Never exposed to frontend.
- `jwtPlugin.ts` uses `supabase.auth.getUser()` for algorithm-agnostic verification

6.4 Redis + BullMQ (Upstash)

Four active queues:

Queue	Worker	Trigger
<code>intake-queue</code>	<code>intakeWorker.ts</code>	Product intake job (scrape + ICP + marketing images)
<code>brief-queue</code>	<code>weeklyBriefWorker.ts</code>	Sunday cron (BullMQ scheduler)
<code>content-queue</code>	<code>contentWorker.ts</code>	Fire-and-forget after strategy generation
<code>mission-execution</code>	<code>missionWorker.ts</code>	Mission creation (concurrency=5, DLQ via DB status='failed')

Scraper jobs run through a separate `scraperQueue.ts` → `scraperWorker.ts` (Playwright, sandboxed).

6.5 Cloudflare

- DNS, DDoS protection

- WAF rules
- Rate limiting: 100 req/min per founder (layered with Fastify rate limit)
- TLS 1.3 minimum, HSTS headers
- Origin IP hidden behind Cloudflare

6.6 AWS KMS

- Used exclusively for OAuth token encryption key management
- Key never stored in DB, never in env vars
- `tokenVault.ts` handles all encrypt/decrypt operations
- Every `decryptToken()` call writes to `audit_logs` first

7. Security Architecture

7.1 Authentication Flow

User → Supabase Auth (TOTP MFA required) → ES256 JWT (15-min)
 → Fastify jwtPlugin → `supabase.auth.getUser()` (algorithm-agnostic) → `founderId` extracted
 → Every route: `request.jwtVerify()` as first line

7.2 Row-Level Security

Every founder-data table has:

```
ALTER TABLE table_name ENABLE ROW LEVEL SECURITY;
CREATE POLICY "table_owner" ON table_name USING (founder_id = auth.uid());
```

Tables with no `founder_id` (e.g., `playbook_signals`, `intelligence_trends`): authenticated SELECT only, INSERT via `service_role`, no UPDATE/DELETE.

7.3 OAuth Token Vault

Plaintext token → AES-256 encrypt (key from AWS KMS) → store `encrypted_token` in `platform_tokens`
 Decrypt flow: → verify `founder_id` matches → write to `audit_logs` → fetch KMS key → decrypt → use
 Rules: → decrypted token NEVER logged, NEVER returned to frontend, NEVER cached

7.4 Anomaly Detection (`auth.middleware.ts`)

- New device fingerprint OR new country → re-authentication required
- Resend alert email to founder

- Audit log entry
- Redis-backed device tracking (per founderId)

7.5 API Security Headers

```
Content-Security-Policy: (strict)
X-Frame-Options: DENY
X-Content-Type-Options: nosniff
Strict-Transport-Security: (via Cloudflare)
```

7.6 Input Validation

- Zod on all inputs (body, params, query) — use `safeParse()` inside handler, never in Fastify `schema:` field
- `sanitizeInput()` in `aiPlatform.ts` strips role markers + instruction overrides (prompt injection defense)
- CORS: `launchmind.com` + `localhost:3000` only

7.7 GDPR Compliance

- `DELETE /founders/me` — purges all personal data (soft-delete on `founders`, hard-delete on all related tables)
- `playbook_signals` NOT deleted (PII-free, anonymized)
- `GET /founders/me/export` — GDPR-compliant JSON export
- India: PDPB 2023 foundations in place

7.8 Audit Logging

- `audit_logs` table: immutable, INSERT only, `REVOKE UPDATE, DELETE FROM authenticated, anon`
- `decryptToken()` always writes before returning
- Admin access: time-boxed (2h max), logged to Axiom, auto-revoked

8. Environment & Secrets

Single env file for local dev: `.env.local` (gitignored, never committed) `.env.dev` has been **deleted**.
`.env.local` replaced it. `backend/src/server.ts` loads `.env.local` on startup.

Key Environment Variables (names only — never values)

```
# Supabase
NEXT_PUBLIC_SUPABASE_URL
NEXT_PUBLIC_SUPABASE_ANON_KEY
SUPABASE_SERVICE_ROLE_KEY
SUPABASE_JWT_SECRET
```

Backend

```
NEXT_PUBLIC_API_URL
FASTIFY_PORT
```

AI

```
ANTHROPIC_API_KEY
REPLICATE_API_TOKEN
ELEVENLABS_API_KEY
CREATOMATE_API_KEY
STABILITY_AI_KEY
```

Payments

```
STRIPE_SECRET_KEY
STRIPE_WEBHOOK_SECRET
RAZORPAY_KEY_ID
RAZORPAY_KEY_SECRET
```

Infrastructure

```
UPSTASH_REDIS_URL
UPSTASH_REDIS_TOKEN
AWS_KMS_KEY_ID
AWS_ACCESS_KEY_ID
AWS_SECRET_ACCESS_KEY
AWS_REGION
```

Services

RESEND_API_KEY
SENTRY_DSN
POSTHOG_KEY
AXIOM_API_KEY
AXIOM_DATASET

Search

GOOGLE_CUSTOM_SEARCH_API_KEY
GOOGLE_CUSTOM_SEARCH_ENGINE_ID

Secrets stored in: Oracle Cloud VM env file (backend) · Vercel env vars (frontend) · GitHub Actions secrets (CI/CD)

Pre-commit check (run before every commit):

```
git grep -rE "(keysecretpasswordtoken)\s=\s['\"] [^\"]{8,}"
```

9. CI/CD Pipeline

GitHub Actions Workflows

`ci.yml` — runs on every PR:

1. npm install (frontend + backend)
 - tsc --noEmit (0 errors required – 5 pre-existing scraper errors excluded)
 - Semgrep SAST scan (blocks on HIGH+)
 - ESLint security plugin
 - npm audit --audit-level=high
 - npx snyk test --severity-threshold=high
 - Vitest (backend unit + integration tests, 349/351 passing)
 - Playwright sanity.spec.ts

deploy.yml — runs on push to **main**:

1. All CI checks pass
 - Build Docker image
 - Push to Oracle Cloud VM via SSH
 - docker-compose pull && docker-compose up -d
 - Run health check

Branch Strategy

```
main      ← production (auto-deploy to Vercel + Oracle VM)
staging   ← DAST target + phase gate
dev       ← integration
feature/* ← branch from dev
security/* ← expedited, 1-reviewer merge to main
```

PR Requirements

- Passing SAST + dependency scan + all tests
- Test coverage for all new paths
- What changed and why + Phase/Week reference
- Security impact statement

10. Branch Strategy & Commit Format

Commit Format

```
type(scope): short description (imperative mood)
```

```
Types: feat  fix  security  refactor  test  docs  chore  migration
```

Code Quality — File Headers (every file)

```
/**
 * @file filename.ts
 * @description What this file does and why it exists.
 * @security Security-relevant behaviour (auth checks, token handling, RLS, audit logging).
 * @dependencies Other services/tables this file reads or writes.
 */
```

Function JSDoc (every exported function)

```
/**
 * One-line summary.
 * @param name - Description
 * @returns Description
 * @throws {ErrorType} When and why
 * @security Any security note specific to this function
 */
```

Continue to: [LMJuly18-02-Database-Schema.md](#)